

ICDFA GRC102: Information Security Governance

Week 1 Lab Assignment: Principles of Information Security Governance

Student Name: JOY ORILADE

Date: 5TH March, 2026

Instructor: Com Idris Aminu

Overview

This lab assignment is designed to reinforce your understanding of information security governance principles and frameworks covered in Week 1. You will analyze governance structures, compare frameworks, and apply governance principles to real-world scenarios.

Learning Objectives

By completing this lab, you will be able to:

- Analyze information security governance structures and their effectiveness
- Compare and contrast major security governance frameworks
- Apply governance principles to real-world security scenarios
- Evaluate the alignment between security governance and business objectives
- Develop recommendations for improving security governance

Instructions

This lab assignment consists of four parts. Complete all parts and submit your responses in a single document. Your responses should be thorough, well-reasoned, and professionally presented.

Part 1: Governance Structure Analysis (25 points)

Scenario: You are a security consultant hired by TechCorp, a mid-sized technology company with 500 employees. The company has experienced rapid growth and is concerned about the effectiveness of its security governance structure. The CEO has provided you with the following information about their current approach:

- Security is managed by the IT department, with the IT Director making most security decisions
- There is no formal security committee or governance body
- The board receives a brief security update once per year
- Security policies exist but are outdated and inconsistently followed
- Security incidents are handled reactively with no formal process
- The company is planning to expand internationally in the next year

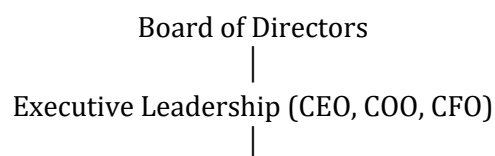
Tasks:

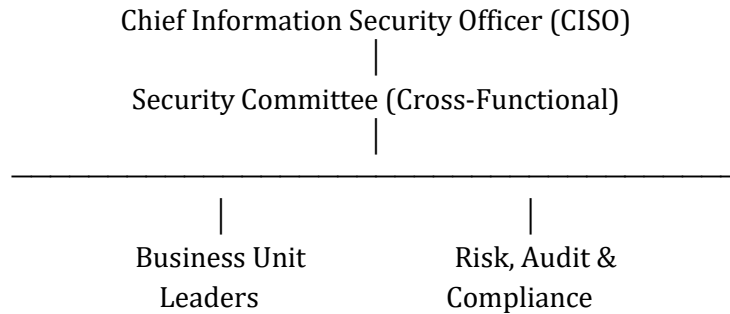
1. Identify at least five specific weaknesses in TechCorp's current security governance approach. For each weakness, explain:
2. The specific governance issue
3. The potential business impact of this weakness
4. How this might affect the company's international expansion plans

WEAKNESS	Governance Issue.	Business Impact	International expansion plans
Security is managed by the IT department, with the IT Director making most security decisions	Security governance is sole centralized to the IT department without an oversight from the management	Increased risk exposure due to the IT director making most decisions	Failure to meet international compliance standards
There is no formal security committee or governance body	No formal Governance in place to oversee security issues	Security decisions are made in silos	Expansion need security governance structure across different departments
The board receives a brief security update once per year	The board receives a brief security update once per year	Poor risk decision making	Board might underestimate international cybersecurity risk as they received brief update
Security policies exist but are outdated and inconsistently followed	Security policies exist but are outdated, not maintain and not enforce	Compliance failure	International expansion required up to date policies
No formal process for security incidents	Security incidents are handled reactively with no formal process	No incident report and lesson learn to serve an continuous improvement	Non compliance with notification of breach for international standards

5. Design an improved security governance structure for TechCorp that addresses the identified weaknesses. Your design should include:
6. A governance organizational chart showing key roles and reporting relationships

ANSWERS: Governance Organizational Chart





7. Descriptions of key governance bodies (committees, working groups, etc.)

Answers:

A. Board of Directors : Ultimate responsibility for governance, setting risk appetite, and approving security strategy

B. Executive Leadership: Sponsorship, resource allocation, and strategic alignment for security program

C. CISO: Security strategy development, program management, reporting to leadership

D. Security Committee: Cross-functional oversight, prioritization, decision-making for security

E. Business Unit Leaders: Integration of security into business processes, compliance with policies

F. Audit and Compliance: Independent assessment, verification of controls, compliance monitoring

8. Defined responsibilities for each governance role/body

ANSWER:

A. Board of Directors: They set risk appetite, approve security strategy, oversee cyber risk as enterprise risk, and review quarterly security reports

B. Executive Leadership: they allocate resources, ensure strategic alignment, and support enforcement of policies.

C. CISO: They develop security strategy and roadmap, maintain security policies, lead risk assessments, report KPIs and risk posture, and oversee incident response.

D. Security Committee: they evaluate risk findings, prioritize remediation efforts, approve policy updates and monitor implementation progress.

E. Business Unit Leaders: they implement security controls within departments, ensure staff compliance, and participate in risk reviews.

F. Audit & Compliance: They conduct independent audits, monitor regulatory compliance (especially for international expansion), and report deficiencies directly to the board

9. Governance processes for security decision-making and oversight

ANSWER:

A. Risk Management Process

- Quarterly enterprise risk assessments
- Maintenance of centralized risk register
- Formal risk acceptance procedures

B. Policy Governance Process

- Annual policy review cycle
- Formal approval workflow
- Mandatory employee acknowledgment
- Enforcement tracking

C. Incident Management Process

- Documented incident response plan
- Defined escalation matrix
- Regulatory breach notification procedures
- Post-incident review and lessons learned

10. Recommendations for board involvement in security governance

ANSWER:

- Ensure that security is not managed by IT department only but involve all board of directors and everyone in the organization
- Establish a formal security committee or governance body
- Established a quarterly security briefing for board of directors and executive leadership
- Update security policies and enforce compliance
- Establish a formal process for security incidents.

11. Explain how your proposed governance structure aligns with at least three core principles of effective information security governance discussed in the course materials.
- Strategic Alignment: Security initiatives aligned with business and business satisfaction with security
 - Risk Management: Risk assessment coverage Risk treatment completion rate
 - resource Optimization : security budget percentage, and return on security investments.
 - Performance measurement: Control effectiveness and security incident metrics.
 - Value Delivery: Cost avoidance through security and business enablement through security

Part 2: Framework Comparison and Selection (25 points)

Scenario: The CIO of MedSecure, a healthcare organization with 2,000 employees and operations in three states, is considering implementing a formal security governance framework. The organization handles sensitive patient data and must comply with HIPAA regulations. The CIO has asked you to evaluate COBIT and ISO 27001 as potential frameworks for MedSecure.

Tasks:

12. Create a detailed comparison table of COBIT and ISO 27001 as security governance frameworks, addressing at least the following aspects:
13. Scope and focus
 14. Structure and components
 15. Governance approach
 16. Implementation and certification
 17. Control selection and risk management
 18. Strengths and limitations
 19. Regulatory alignment (especially with HIPAA)
 20. Resource requirements

	COBIT	ISO 27001
Scope and focus	is a framework for the governance and management of enterprise information and technology that supports enterprise objectives. It provides a comprehensive framework that assists enterprises in achieving their objectives for the	is an international standard for managing information security that provides a framework for establishing, implementing, maintaining, and continually improving an ISMS.

	governance and management of enterprise IT	
Structure and components	Processes, organizational Structures, Information, People, Skills and Competencies	Annex A controls, risk assessment and treatment requirements
Governance approach	Top-down governance model with strong board and executive oversight	Risk-based management system with leadership commitment and continual improvement
Implementation and certification	Not certifiable	Certifiable standard (organizations can achieve ISO 27001 certification)
Control selection and risk management	Broad IT risk management guidance; not control-specific	Requires formal risk assessment and selection of controls from Annex A
Strengths	Strong governance structure, enterprise alignment, performance measurement, and maturity modeling	Globally recognized, structured, strong risk management, certifiable, and detailed control guidance
limitation	Broad and complex; less detailed security controls; not compliance-focused	Focused on security only; less emphasis on enterprise IT governance
Regulatory alignment (especially with HIPAA)	Requires executive engagement, governance maturity, cross-functional coordination	Requires documentation, risk assessments, internal audits, possible certification costs
Resource requirements	Requires executive engagement, governance maturity, cross-functional coordination	Requires documentation, risk assessments, internal audits, possible certification costs

21. Based on your comparison and MedSecure's context, recommend which framework (or combination of frameworks) would be most appropriate. Provide a detailed justification for your recommendation that addresses:

ANSWER - ISO 27001

22. Alignment with healthcare industry requirements

Answers

MedSecure handles sensitive patient data and must comply with HIPAA regulation.

ISO 27001 provides structured risk management and control implementation.

- Annex A controls align well with HIPAA's administrative, physical, and technical safeguards.
- Certification strengthens trust with patients, partners, and regulators.

23. Suitability for MedSecure's size and complexity

ANSWERS:

With 2,000 employees across three states: ISO 27001 is scalable and suitable for multi-site organizations. It provides structured documentation and standardized processes

24. Ability to address HIPAA compliance requirements

ANSWER:

ISO 27001 directly supports requirements through:

- Mandatory risk assessment
- Control implementation
- Policy documentation
- Monitoring and internal audits

25. Implementation considerations and challenges

ANSWER

Challenges:

- Cultural resistance
- Documentation workload
- Resource allocation
- Change management

26. Long-term sustainability and evolution

ANSWER

ISO 27001 ensures:

- Continuous improvement (PDCA cycle)
- Ongoing risk reassessment
- Internal audits
- Management review

27. Outline a high-level implementation roadmap for your recommended framework(s) at MedSecure, including:

28. Key implementation phases

ANSWER

Phase 1: Initiation & Planning (Months 1-2)

- Executive approval
- Appoint CISO/ISMS Manager

- Define scope of ISMS
- Conduct initial HIPAA & ISO gap assessment

Phase 2: Risk Assessment & Design (Months 3–5)

- Conduct enterprise-wide risk assessment
- Identify PHI data flows
- Select ISO 27001 controls
- Develop policies and procedures

Phase 3: Implementation (Months 6–10)

- Implement technical controls
- Train workforce
- Establish incident response plan
- Develop monitoring mechanisms

Phase 4: Internal Audit & Certification (Months 11–12)

- Conduct internal audit
- Management review
- Remediation
- External ISO 27001 certification audit (optional but recommended)

29. Critical success factors

ANSWERS

- Strong leadership support
- Clear project charter

30. Potential challenges and mitigation strategies

ANSWERS

Challenges:

Asset identification complexity

Risk evaluation consistency

Mitigation:

Use structured risk methodology

Cross-department workshops

31. Resource requirements

ANSWER

- ISMS team
- Compliance officer
- IT security tools
- Legal advisory

32. Timeline considerations

ANSWERS

Total Estimated Duration: 1–12 Months

- Foundational governance: 1–3 months
- Full ISMS implementation: 4–6 months
- Certification readiness: 7–12 months

Part 3: Case Study Analysis (30 points)

Scenario: Review the following case study and answer the questions that follow.

Equifax Data Breach: A Governance Failure

In 2017, Equifax, one of the three largest credit bureaus in the United States, suffered a massive data breach that exposed the personal information of approximately 147 million people. The breach occurred due to an unpatched vulnerability in the Apache Struts web application framework, which Equifax used for its online dispute portal.

Key facts about the breach and its aftermath:

- Equifax was notified about the vulnerability in March 2017 but failed to patch affected systems
- The breach occurred from May to July 2017 but wasn't discovered until July 29, 2017
- Equifax waited until September 7, 2017, to publicly disclose the breach
- The company's Chief Security Officer and Chief Information Officer resigned shortly after the disclosure
- Investigations revealed numerous security governance failures, including inadequate vulnerability management, poor network segmentation, and expired SSL certificates
- The breach resulted in a \$575 million settlement with the FTC, CFPB, and states
- Congressional hearings highlighted significant governance failures, including the lack of clear security accountability and inadequate board oversight

Tasks:

33. Analyze the Equifax breach specifically from a security governance perspective. Identify and explain at least five specific governance failures that contributed to the breach or its impact. For each failure, explain:

34. The specific governance issue

35. How it contributed to the breach or its impact

36. Which governance principle or best practice was violated

Governance failures	Governance issue	How it contributed to the breach or its impact	Governance principle or best practice was violated
Inadequate vulnerability management	Equifax failed to patch a known vulnerability after receiving notification in March 2017.	The unpatched vulnerability allowed attackers to exploit the system for months, leading to massive data exfiltration.	Failure of formal patch governance and oversight
Poor network segmentation	Sensitive systems were insufficiently segmented	Attackers gained broad access once inside the environment.	Defense-in-Depth & Risk Mitigation
Expired SSL certificates	Equifax had expired SSL certificates on critical systems, which prevented proper inspection of encrypted network traffic.	security monitoring tools could not effectively decrypt and inspect outbound traffic. As a result, attackers were able to exfiltrate sensitive data for an extended period without detection	Lack of control validation and monitoring oversight
Delayed Public Disclosure	The breach occurred from May to July 2017 but wasn't discovered until July 29, 2017 and Equifax waited until September 7, 2017, to publicly disclose the breach	The delay amplified reputational damage and breach resulted in a \$575 million settlement with the FTC, CFPB, and states	Lack of proper or timely communication while Governance includes timely stakeholder communication
Weak Governance or board of directors oversight	Board oversight of cybersecurity was limited and lacked depth.	Cyber risk was not treated as an enterprise-level strategic risk, reducing prioritization and resource allocation	Board Accountability & Strategic Alignment

37. If you had been the CISO at Equifax before the breach, describe the governance structures, processes, and controls you would have implemented to prevent the breach. Be specific about:

38. Governance bodies and their responsibilities

ANSWER

1. Board of Directors:

- Compliance Oversight: Ensuring adherence to relevant laws and regulations, reviewing significant compliance issues and their remediation plans, and approving frameworks for managing compliance obligations.
- Performance Monitoring: Reviewing the effectiveness of the security program, monitoring key security metrics and indicators, and ensuring the continuous improvement of security capabilities.
- Quarterly cyber risk reviews
- Approval of risk appetite
- Oversight of vulnerability metrics

2. Executive Leadership

- Security Leadership: Establishing a pervasive security-conscious culture, demonstrating unwavering commitment to security through both words and actions, and ensuring that security considerations are integral to all strategic business decisions.
- Organizational Structure: Defining the security governance structure, establishing clear reporting lines for security functions, and ensuring that security leaders are vested with appropriate authority
- Resource Management: Allocating resources based on identified risk priorities, balancing security requirements with broader business objectives, and ensuring that security investments deliver demonstrable value.
- Performance Accountability: Holding business units accountable for their security performance, regularly reviewing security metrics and program effectiveness, and taking decisive corrective action when security goals are not met.
- Crisis Leadership: Leading the organization through significant security incidents, making critical decisions during security crises, and ensuring appropriate communication with stakeholders during such events
- Monthly risk reviews
- Prioritization of remediation activities

3. Board Reporting and Communication

Effective communication between security leadership and the board is paramount for sound governance. This includes:

- Reporting Framework: Implementing regular security briefings (typically quarterly), conducting annual comprehensive security program reviews, and ensuring immediate notification of significant security events.
- Key Reporting Areas: Providing updates on the security risk posture and any significant changes, major security initiatives and their progress, compliance status and regulatory developments, summaries of security incidents and lessons learned, and emerging threats with strategic responses.

- **Effective Communication Approaches:** Focusing on business impact rather than technical details, utilizing clear metrics and trend analysis, providing essential context for security issues and recommendations, including benchmarking against industry peers, and presenting options with associated risks and benefits.

- **Board Security Education:** Conducting regular board education sessions on pertinent security topics, providing updates on the evolving threat landscape, facilitating scenario-based discussions of security risks, and incorporating external expert perspectives on security trends.

4. Security Leadership Roles: E.g Chief Information Security Officer (CISO)

The CISO is the senior executive responsible for establishing and maintaining the enterprise security vision, strategy, and program. Key responsibilities include:

- **Strategic Leadership:** Developing and implementing the overarching security strategy, aligning security initiatives with business objectives, and advising executive leadership on all security matters.

- **Program Management:** Establishing the security management framework, overseeing security policies, standards, and procedures, and managing the security organization and its resources.

- **Risk Management:** Identifying and assessing security risks, developing effective risk treatment strategies, and reporting on the organization's risk posture to executive leadership and the board.

5. Operational Security Roles: Eg Security Analysts

Security Analysts are responsible for the day-to-day monitoring and analysis of security events. Their key responsibilities include:

- **Threat Monitoring:** Continuously monitoring security systems, logs, and alerts for suspicious activities or indicators of compromise.

- **Incident Detection:** Identifying and escalating potential security incidents based on analysis of security data.

- **Vulnerability Management:** Assisting in the identification, assessment, and remediation of vulnerabilities within systems and applications.

- **Security Tool Management:** Configuring, maintaining, and optimizing security tools such as SIEM (Security Information and Event Management) systems, intrusion detection/prevention systems (IDPS), and antivirus solutions.

- **Reporting:** Generating regular reports on security posture, incidents, and compliance

6. Accountability and Delegation: E.g Establishing Accountability

Clear accountability is fundamental to effective security governance. This involves:

- **Defined Roles:** Clearly defining roles and responsibilities for all security-related activities.
- **Performance Metrics:** Establishing measurable performance metrics for security objectives and holding individuals and teams accountable for achieving them.
- **Reporting Lines:** Ensuring clear reporting lines for security incidents, risks, and compliance issues.
- **RACI Matrix:** Utilizing a RACI (Responsible, Accountable, Consulted, Informed) matrix to clarify roles for specific tasks and decisions.

7 Governance Documentation: Comprehensive and accessible documentation is vital for maintaining a robust security governance framework. Key documentation includes:

- **Security Policies:** High-level statements outlining the organization's stance on information security.
- **Security Standards:** Mandatory requirements that support security policies and provide specific controls.
- **Security Procedures:** Detailed, step-by-step instructions for implementing security controls and performing security-related tasks.
- **Security Baselines:** Minimum security configurations for systems and applications.
- **Risk Management Framework:** Documentation outlining the organization's approach to identifying, assessing, and treating risks.
- **Incident Response Plan:** A detailed plan for responding to security incidents.
- **Security Committee Charters:** Documents defining the purpose, scope, membership, and responsibilities of security committees.
- **Roles and Responsibilities Matrix:** A detailed matrix mapping specific security tasks to responsible roles (e.g., RACI matrix)

39. Accountability mechanisms

ANSWER

Escalation unpatched vulnerability in the Apache Struts web application framework for overdue remediation

40. Risk management processes

ANSWER

Mandatory remediation timelines based on severity of breach

41. Board reporting and oversight

ANSWER

-

- Providing updates on the security risk posture and any significant changes, major security initiatives and their progress, compliance status and regulatory developments, summaries of security incidents and lessons learned, and emerging threats with strategic responses

- Incident response metrics

- Maturity assessments

42. Policy enforcement mechanisms

ANSWER

Ensuring that departmental employees understand and adhere to security Policies and procedures

43. Vulnerability management governance

ANSWER

- Risk prioritization
- Defined remediation deadlines
- Executive escalation if missed
- Validation and closure verification

44. Discuss how the Equifax breach has influenced security governance practices across the industry. Address:

45. Changes in regulatory approaches to security governance

ANSWER

- Increased enforcement of data protection laws
- Stronger regulatory scrutiny of governance programs
- Greater focus on demonstrable risk management processes
- Heavier financial penalties for governance failures

46. Evolution of board involvement in security oversight

ANSWER

- The security team like the CISO should do a regular briefing to the board and executive leadership of the organization

47. Shifts in executive accountability for security

ANSWER

Increased resignations following breaches
Mandatory certification

48. Lessons learned for security governance in similar organizations

ANSWER

- Board involvement for oversight at all level
- Continuous monitoring
- Accountability of transparency on notification of breach
- Security risk is also a governance issue

Part 4: Governance Principles Application (20 points)

Scenario: You are the newly appointed CISO at GlobalFinance, a multinational financial services company with 15,000 employees across 20 countries. The company has a decentralized structure, with significant autonomy for regional operations. The CEO has asked you to develop a set of security governance principles that can be applied consistently across the organization while respecting regional differences.

Tasks:

49. Develop a set of 7-10 security governance principles for GlobalFinance. For each principle:

50. Provide a clear, concise statement of the principle

51. Explain its importance in the financial services context

52. Describe how it would be applied in practice

53. Identify potential implementation challenges in a decentralized environment

Security governance principles	A clear, concise statement of the principle	Importance in the financial services context	Describe how it would be applied in practice	Identify potential implementation challenges in a decentralized environment
Clear Accountability	Every security risk, asset, and control must have a clearly defined owner at both global and regional levels.	Financial institutions require traceable accountability to regulators and stakeholders.	• Regional security leads responsible for local implementation • RACI matrices for all governance processes	Overlapping responsibilities between global and regional teams.
Regulatory Compliance	Security controls must proactively integrate global and local regulatory requirements into system	Financial services are subject to diverse regulations	• Central compliance framework mapped to local	Conflicting regulatory requirements across jurisdictions.

	design and operations.		regulations • Regional compliance officers aligned to global governance	
Transparency and Board Oversight	Cybersecurity shall be treated as an enterprise risk with regular board-level oversight	Regulators increasingly require board accountability for cyber risk.	Quarterly board reporting	Ensuring consistent reporting metrics across regions.
Data Protection and Privacy	Protection of customer and financial data shall be prioritized across all operations.	Customer trust and regulatory compliance depend on robust data governance	• Global data classification standard • Encryption requirements	Data transfer restrictions across borders.
Continuous Monitoring and Improvement	Security governance shall include ongoing monitoring, testing, and maturity assessment.	Threat landscape evolves rapidly in financial services.	Maturity assessments	Resource disparities across regions.
Governance Model	Security governance shall operate under centralized oversight with distributed regional execution.	Ensures strategic alignment while respecting local regulatory and cultural differences.	• Global policies (minimum baseline) • Regional adaptations approved through formal process	Maintaining consistency without stifling autonomy.

54. Explain how your governance principles address the balance between:

55. Global consistency and local flexibility

ANSWER

• Global minimum control baseline

• Regions may implement stricter controls where required

56. Security requirements and business agility

ANSWER

- Risk-based prioritization
- Embedded security in innovation lifecycle
- Fast-track review process for strategic initiatives

57. Compliance obligations and innovation needs

ANSWER

- Compliance-by-design model
- Regulatory advisory embedded in innovation teams

58. Centralized oversight and distributed responsibility

ANSWER

- Regional CISO structure with dual reporting
- Global KPI monitoring

59. Design a governance mechanism for ensuring adherence to these principles across the organization. Your design should address:

60. How adherence will be measured and reported

ANSWER

Adherence measured via:

- Global cybersecurity KPIs (patch compliance, incident response times, audit findings)
- Annual maturity assessments
- Quarterly regional compliance attestations
- Risk posture scoring dashboards

Reported to:

- Executive Committee
- Board Risk Committee

61. Accountability for implementation at different organizational levels

ANSWER

Global Level

- Group CISO accountable for global governance
- Board Risk Committee oversight

Regional Level

- Regional CISOs accountable for implementation
- Local business leaders responsible for compliance within their operations

62. Processes for handling exceptions or conflicts

ANSWER

- Formal exception request submission
- Risk impact assessment
- Approval by Global Security Governance Committee
- Defined expiration date and compensating controls

63. Approaches for continuous improvement of the principles

ANSWER

- Annual review of governance principles
- Lessons learned from incidents
- Regulatory updates integration
- Independent internal audit validation
- External benchmarking against industry standard

Submission Requirements

Submit your completed lab assignment as a single document with the following characteristics:

- Professional formatting with clear section headings
- Well-organized responses that directly address each task
- Proper citation of any external sources used
- Appropriate use of security governance terminology
- Clear, concise, and grammatically correct writing

Grading Rubric

Part 1: Governance Structure Analysis (25 points)

- Comprehensive identification of governance weaknesses (5 points)
- Thorough analysis of business impacts (5 points)
- Well-designed governance structure (10 points)
- Clear alignment with governance principles (5 points)

Part 2: Framework Comparison and Selection (25 points)

- Detailed and accurate framework comparison (10 points)
- Well-justified recommendation (5 points)
- Comprehensive implementation roadmap (5 points)
- Consideration of healthcare-specific requirements (5 points)

Part 3: Case Study Analysis (30 points)

- Insightful analysis of governance failures (10 points)
- Comprehensive preventative governance approach (10 points)
- Thoughtful discussion of industry impact (5 points)
- Application of course concepts to the case (5 points)

Part 4: Governance Principles Application (20 points)

- Well-developed governance principles (10 points)
- Thoughtful balance of competing concerns (5 points)
- Effective governance mechanism design (5 points)

Due Date

This assignment is due by 11:59 PM via the course learning management system.

Academic Integrity

Your submitted work must be your own. Properly cite any sources used according to APA format. Plagiarism or other academic integrity violations will result in disciplinary action according to the ICDFFA Academic Integrity Policy.